

SENATE No. 33

The Commonwealth of Massachusetts

PRESENTED BY:

William J. Driscoll, Jr.

To the Honorable Senate and House of Representatives of the Commonwealth of Massachusetts in General Court assembled:

The undersigned legislators and/or citizens respectfully petition for the adoption of the accompanying bill:

An Act establishing the Comprehensive Massachusetts Consumer Data Privacy Act.

PETITION OF:

NAME:

William J. Driscoll, Jr.

DISTRICT/ADDRESS:

Norfolk, Plymouth and Bristol

SENATE No. 33

By Mr. Driscoll, a petition (accompanied by bill, Senate, No. 33) of William J. Driscoll, Jr. for legislation to establish the comprehensive Massachusetts consumer data privacy act. Advanced Information Technology, the Internet and Cybersecurity.

The Commonwealth of Massachusetts

In the One Hundred and Ninety-Fourth General Court
(2025-2026)

An Act establishing the Comprehensive Massachusetts Consumer Data Privacy Act.

Be it enacted by the Senate and House of Representatives in General Court assembled, and by the authority of the same, as follows:

1 SECTION 1. The General Laws, as appearing in the 2022 Official Edition, are hereby
2 amended by inserting after chapter 93L the following chapter:-

3 CHAPTER 93M.

4 Massachusetts Consumer Privacy Act

5 Section 1. As used in this chapter, unless the context otherwise indicates, the following
6 terms have the following meanings.

7 “Adult”, any individual who is at least eighteen years of age.

8 "Affiliate", a legal entity that shares common branding with another legal entity or
9 controls, is controlled by or is under common control with another legal entity. For the purposes
10 of this subdivision, "control" or "controlled" means (A) ownership of, or the power to vote, more
11 than fifty per cent of the outstanding shares of any class of voting security of a company, (B)

control in any manner over the election of a majority of the directors or of individuals exercising similar functions, or (C) the power to exercise controlling influence over the management of a company.

"Authenticate", to use reasonable means to determine that a request to exercise any of the rights afforded pursuant to this act is being made by, or on behalf of, the consumer who is entitled to exercise such consumer rights with respect to the personal data at issue.

"Biometric data", data generated by automatic measurements of an individual's biological characteristics, such as a fingerprint, a voiceprint, eye retinas, irises or other unique biological patterns or characteristics that are used to identify a specific individual. "Biometric data" does not include (A) a digital or physical photograph, (B) an audio or video recording, or (C) any data generated from a digital or physical photograph, or an audio or video recording, unless such data is generated to identify a specific individual.

"Business associate" shall have the same meaning as provided in the Health Insurance Portability and Accountability Act of 1996, 42 USC 1320d.

"Child" shall have the same meaning as provided in the federal Children's Online Privacy Act, 15 U.S.C. 6501.

"Consent", a clear affirmative act signifying a consumer's freely given, specific, informed and unambiguous agreement to allow the processing of personal data relating to the consumer.

"Consent" may include a written statement, including by electronic means, or any other unambiguous affirmative action. "Consent" does not include (A) acceptance of a general or broad terms of use or similar document that contains descriptions of personal data processing

33 along with other, unrelated information, (B) hovering over, muting, pausing or closing a given
34 piece of content, or (C) agreement obtained through the use of dark patterns.

35 "Consumer", an individual who is a resident of this state. "Consumer" does not include an
36 individual acting in a commercial or employment context or as an employee, owner, director,
37 officer or contractor of a company, partnership, sole proprietorship, nonprofit or government
38 agency whose communications or transactions with the controller occur solely within the context
39 of that individual's role with the company, partnership, sole proprietorship, nonprofit or
40 government agency.

41 "Consumer Health Data", means any personal data that a controller uses to identify a
42 consumer's physical or mental health condition or diagnosis, and includes, but is not limited to,
43 gender-affirming health data and reproductive or sexual health data.

44 "Controller", an individual who, or legal entity that, alone or jointly with others
45 determines the purpose and means of processing personal data.

46 "COPPA", the Children's Online Privacy Protection Act of 1998, 15 USC 6501 et seq.,
47 and the regulations, rules, guidance and exemptions adopted pursuant to said act, as said act and
48 such regulations, rules, guidance and exemptions may be amended from time to time.

49 "Covered entity", shall have the same meaning as provided in the Health Insurance
50 Portability and Accountability Act of 1996, 42 USC 1320d.

51 "Dark pattern", (A) a user interface designed or manipulated with the effect of
52 substantially subverting or impairing user autonomy, decision-making or choice, and (B)

includes, but is not limited to, any practice the Federal Trade Commission refers to as a "dark pattern".

"Decisions that produce legal or similarly significant effects concerning the consumer", decisions made by the controller that result in the provision or denial by the controller of financial or lending services, housing, insurance, education enrollment or opportunity, criminal justice, employment opportunities, health care services or access to basic necessities such as food and water.

"De-identified data", data that cannot reasonably be used to infer information about, or otherwise be linked to, an identified or identifiable individual, or a device linked to such individual, if the controller that possesses such data (A) takes reasonable measures to ensure that such data cannot be associated with an individual, (B) publicly commits to process such data only in a de-identified fashion and not attempt to re-identify such data, and (C) contractually obligates any recipients of such data to satisfy the criteria set forth in subparagraphs (A) and (B) of this subdivision.

"Gender-affirming health care services" shall have the same meaning as provided in section 1 of chapter 9A of the General Laws as amended by chapter 127 of the Acts of 2022.

"Gender-affirming health data", any personal data concerning an effort made by a consumer to seek, or a consumer's receipt of, gender-affirming health care services.

"Geofence", any technology that uses global positioning coordinates, cell tower connectivity, cellular data, radio frequency identification, wireless fidelity technology data or any other form of location detection, or any combination of such coordinates, connectivity, data, identification or other form of location detection, to establish a virtual boundary.

“Heightened risk of harm to minors”, processing minors' personal data in a manner that presents any reasonably foreseeable risk of (A) any unfair or deceptive treatment of, or any unlawful disparate impact on, minors, (B) any financial, physical or reputational injury to minors, or (C) any physical or other intrusion upon the solitude or seclusion, or the private affairs or concerns, of minors if such intrusion would be offensive to a reasonable person;

"HIPAA", the Health Insurance Portability and Accountability Act of 1996, 42 USC 1320d et seq., as amended from time to time.

"Identified or identifiable individual", an individual who can be readily identified, directly or indirectly.

"Institution of higher education", any individual who, or school, board, association, limited liability company or corporation that, is licensed or accredited to offer one or more programs of higher learning leading to one or more degrees.

“Mental health facility”, any health care facility in which at least seventy per cent of the health care services provided in such facility are mental health services.

“Minor”, any consumer who is younger than eighteen years of age.

"Nonprofit organization", any organization that is exempt from taxation under Section 501(c)(3), 501(c)(4), 501(c)(6) or 501(c)(12) of the Internal Revenue Code of 1986, or any subsequent corresponding internal revenue code of the United States, as amended from time to time.

“Online service, product or feature”, any service, product or feature that is provided online. "Online service, product or feature" does not include any (A) telecommunications

service, as defined in 47 USC 153, as amended from time to time, (B) broadband Internet access service, as defined in 47 CFR 54.400, as amended from time to time, or (C) delivery or use of a physical product;

"Personal data", any information that is linked or reasonably linkable to an identified or identifiable individual. "Personal data" does not include de-identified data or publicly available information.

"Precise geolocation data", information derived from technology, including, but not limited to, global positioning system level latitude and longitude coordinates or other mechanisms, that directly identifies the specific location of an individual with precision and accuracy within a radius of one thousand seven hundred fifty feet. "Precise geolocation data" does not include: (i) the content of communications; or (ii) any data generated by or connected to advanced utility metering infrastructure systems or equipment for use by a utility.

"Process" or "processing", any operation or set of operations performed, whether by manual or automated means, on personal data or on sets of personal data, such as the collection, use, storage, disclosure, analysis, deletion or modification of personal data.

"Processor", an individual who, or legal entity that, processes personal data on behalf of a controller.

"Profiling", any form of automated processing performed on personal data to evaluate, analyze or predict personal aspects related to an identified or identifiable individual's economic situation, health, personal preferences, interests, reliability, behavior, location or movements.

"Protected health information", shall have the same meaning as provided in HIPAA.

117 "Pseudonymous data", personal data that cannot be attributed to a specific individual
118 without the use of additional information, provided such additional information is kept separately
119 and is subject to appropriate technical and organizational measures to ensure that the personal
120 data is not attributed to an identified or identifiable individual.

121 "Publicly available information", information that (A) is lawfully made available through
122 federal, state or municipal government records or widely distributed media, or (B) a controller
123 has a reasonable basis to believe a consumer has lawfully made available to the general public.

124 "Reproductive or sexual health care", any health care-related services or products
125 rendered or provided concerning a consumer's reproductive system or sexual well-being,
126 including, but not limited to, any such service or product rendered or provided concerning (A) an
127 individual health condition, status, disease, diagnosis, diagnostic test or treatment, (B) a social,
128 psychological, behavioral or medical intervention, (C) a surgery or procedure, including, but not
129 limited to, an abortion, (D) a use or purchase of a medication, including, but not limited to, a
130 medication used or purchased for the purposes of an abortion, (E) a bodily function, vital sign or
131 symptom, (F) a measurement of a bodily function, vital sign or symptom, or (G) an abortion,
132 including, but not limited to, medical or nonmedical services, products, diagnostics, counseling
133 or follow-up services for an abortion.

134 "Reproductive or sexual health data", any personal data concerning an effort made by a
135 consumer to seek, or a consumer's receipt of, reproductive or sexual health care.

136 "Reproductive or sexual health facility", any health care facility in which at least seventy
137 per cent of the health care-related services or products rendered or provided in such facility are
138 reproductive or sexual health care.

"Sale of personal data", the exchange of personal data for monetary or other valuable consideration by the controller to a third party. "Sale of personal data" does not include (A) the disclosure of personal data to a processor that processes the personal data on behalf of the controller, (B) the disclosure of personal data to a third party for purposes of providing a product or service requested by the consumer, (C) the disclosure or transfer of personal data to an affiliate of the controller, (D) the disclosure of personal data where the consumer directs the controller to disclose the personal data or intentionally uses the controller to interact with a third party, (E) the disclosure of personal data that the consumer (i) intentionally made available to the general public via a channel of mass media, and (ii) did not restrict to a specific audience, or (F) the disclosure or transfer of personal data to a third party as an asset that is part of a merger, acquisition, bankruptcy or other transaction, or a proposed merger, acquisition, bankruptcy or other transaction, in which the third party assumes control of all or part of the controller's assets.

"Sensitive data", personal data that includes (A) data revealing racial or ethnic origin, religious beliefs, mental or physical health condition or diagnosis, sex life, sexual orientation or citizenship or immigration status, (B) the processing of genetic or biometric data for the purpose of uniquely identifying an individual, (C) personal data collected from a known child, (D) precise geolocation data; (E) status as transgender or nonbinary; (F) consumer health data; or (G) data concerning an individual's status as victim of a crime.

"Targeted advertising", displaying advertisements to a consumer where the advertisement is selected based on personal data obtained or inferred from that consumer's activities over time and across nonaffiliated Internet web sites or online applications to predict such consumer's preferences or interests. "Targeted advertising" does not include (A) advertisements based on activities within a controller's own Internet web sites or online applications, (B) advertisements

based on the context of a consumer's current search query, visit to an Internet web site or online application, (C) advertisements directed to a consumer in response to the consumer's request for information or feedback, or (D) processing personal data solely to measure or report advertising frequency, performance or reach.

"Third party", an individual or legal entity, such as a public authority, agency or body, other than the consumer, controller or processor or an affiliate of the processor or the controller.

"Trade secret", shall have the same meaning as provided in section 2 of chapter 93 of the General Laws.

Section 2. The provisions of this act apply to persons that conduct business in this state or persons that produce products or services that are targeted to residents of this state and that during the preceding calendar year: (A) Controlled or processed the personal data of not less than one hundred thousand consumers, excluding personal data controlled or processed solely for the purpose of completing a payment transaction; or (B) controlled or processed the personal data of not less than twenty-five thousand consumers and derived more than twenty-five per cent of their gross revenue from the sale of personal data.

Section 3. (a) The provisions of this act do not apply to any: (1) Body, authority, board, bureau, commission, district or agency of this state or of any political subdivision of this state, or person who has entered into a contract with such entity while such person is processing consumer health data on behalf of such entity; (2) institution of higher education; (2) national securities association that is registered under 15 USC 78o-3 of the Securities Exchange Act of 1934, as amended from time to time; (3) financial institution or data subject to Title V of the

Gramm-Leach-Bliley Act, 15 USC 6801 et seq.; or (4) covered entity or business associate, as defined in 45 CFR 160.103.

(b) The following information and data is exempt from of the provisions of this act:

(1) Protected health information under HIPAA; (2) patient-identifying information for purposes of 42 USC 290dd-2; (3) identifiable private information for purposes of the federal policy for the protection of human subjects under 45 CFR 46; (4) identifiable private information that is otherwise information collected as part of human subjects research pursuant to the good clinical practice guidelines issued by the International Council for Harmonization of Technical Requirements for Pharmaceuticals for Human Use; (5) the protection of human subjects under 21 CFR Parts 6, 50 and 56, or personal data used or shared in research, as defined in 45 CFR 164.501, that is conducted in accordance with the standards set forth in this subdivision and subdivisions (3) and (4) of this subsection, or other research conducted in accordance with applicable law; (6) information and documents created for purposes of the Health Care Quality Improvement Act of 1986, 42 USC 11101 et seq.; (7) information derived from any of the health care related information listed in this subsection that is deidentified in accordance with the requirements for de-identification pursuant to HIPAA; (8) information originating from and intermingled to be indistinguishable with, or information treated in the same manner as, information exempt under this subsection that is maintained by a covered entity or business associate, program or qualified service organization, as specified in 42 USC 290dd-2, as amended from time to time; (9) information used for public health activities and purposes as authorized by HIPAA, community health activities and population health activities; (10) the collection, maintenance, disclosure, sale, communication or use of any personal information bearing on a consumer's credit worthiness, credit standing, credit capacity, character, general

206 reputation, personal characteristics or mode of living by a consumer reporting agency, furnisher
207 or user that provides information for use in a consumer report, and by a user of a consumer
208 report, but only to the extent that such activity is regulated by and authorized under the Fair
209 Credit Reporting Act, 15 USC 1681 et seq., as amended from time to time; (11) personal data
210 collected, processed, sold or disclosed in compliance with the Driver's Privacy Protection Act of
211 1994, 18 USC 2721 et seq., as amended from time to time; (12) personal data regulated by the
212 Family Educational Rights and Privacy Act, 20 USC 1232g et seq., as amended from time to
213 time; (13) personal data collected, processed, sold or disclosed in compliance with the Farm
214 Credit Act, 12 USC 2001 et seq., as amended from time to time; (14) data processed or
215 maintained (A) in the course of an individual applying to, employed by or acting as an agent or
216 independent contractor of a controller, processor or third party, to the extent that the data is
217 collected and used within the context of that role, (B) as the emergency contact information of an
218 individual under Section 1 of this act used for emergency contact purposes, or (C) that is
219 necessary to retain to administer benefits for another individual relating to the individual who is
220 the subject of the information under subdivision (1) of this subsection and used for the purposes
221 of administering such benefits; and (15) personal data collected, processed, sold or disclosed in
222 relation to price, route or service, as such terms are used in the Airline Deregulation Act, 49 USC
223 40101 et seq., as amended from time to time, by an air carrier subject to said act, to the extent
224 Section 1 of this act are preempted by the Airline Deregulation Act, 49 USC 41713, as amended
225 from time to time.

226 (c) Controllers and processors that comply with the verifiable parental consent
227 requirements of COPPA shall be deemed compliant with any obligation to obtain parental
228 consent pursuant to Section 1 of this act.

Section 4. (a) A consumer shall have the right to: (1) confirm whether or not a controller is processing the consumer's personal data and access such personal data, unless such confirmation or access would require the controller to reveal a trade secret; (2) correct inaccuracies in the consumer's personal data, taking into account the nature of the personal data and the purposes of the processing of the consumer's personal data; (3) delete personal data provided by, or obtained about, the consumer; (4) obtain a copy of the consumer's personal data processed by the controller, in a portable and, to the extent technically feasible, readily usable format that allows the consumer to transmit the data to another controller without hindrance, where the processing is carried out by automated means, provided such controller shall not be required to reveal any trade secret; and (5) opt out of the processing of the personal data for purposes of (A) targeted advertising, (B) the sale of personal data, except as provided in subsection (b) of section 6 of this act, or (C) profiling in furtherance of solely automated decisions that produce legal or similarly significant effects concerning the consumer.

(b) A consumer may exercise rights under this section by a secure and reliable means established by the controller and described to the consumer in the controller's privacy notice. A consumer may designate an authorized agent in accordance with section 5 of this act to exercise the rights of such consumer to opt out of the processing of such consumer's personal data for purposes of subdivision (5) (A) and (B) of subsection (a) of this section on behalf of the consumer. In the case of processing personal data of a known child, the parent or legal guardian may exercise such consumer rights on the child's behalf. In the case of processing personal data concerning a consumer subject to a guardianship, conservatorship or other protective arrangement, the guardian or the conservator of the consumer may exercise such rights on the consumer's behalf.

(c) Except as otherwise provided in this act, a controller shall comply with a request by a consumer to exercise the consumer rights authorized pursuant to said sections as follows:

(1) A controller shall respond to the consumer without undue delay, but not later than forty-five days after receipt of the request. The controller may extend the response period by forty-five additional days when reasonably necessary, considering the complexity and number of the consumer's requests, provided the controller informs the consumer of any such extension within the initial forty-five-day response period and of the reason for the extension.

(2) If a controller declines to take action regarding the consumer's request, the controller shall inform the consumer without undue delay, but not later than forty-five days after receipt of the request, of the justification for declining to take action and instructions for how to appeal the decision.

(3) Information provided in response to a consumer request shall be provided by a controller, free of charge, once per consumer during any twelve-month period. If requests from a consumer are manifestly unfounded, technically infeasible, excessive or repetitive, the controller may charge the consumer a reasonable fee to cover the administrative costs of complying with the request or decline to act on the request. The controller bears the burden of demonstrating the manifestly unfounded, technically infeasible, excessive or repetitive nature of the request.

(4) If a controller is unable to authenticate a request to exercise any of the rights afforded under subdivisions (1) to (4), inclusive, of subsection (a) of this section using commercially reasonable efforts, the controller shall not be required to comply with a request to initiate an action pursuant to this section and shall provide notice to the consumer that the controller is unable to authenticate the request to exercise such right or rights until such

consumer provides additional information reasonably necessary to authenticate such consumer and such consumer's request to exercise such right or rights. A controller shall not be required to authenticate an opt-out request, but a controller may deny an opt-out request if the controller has a good faith, reasonable and documented belief that such request is fraudulent. If a controller denies an opt-out request because the controller believes such request is fraudulent, the controller shall send a notice to the person who made such request disclosing that such controller believes such request is fraudulent, why such controller believes such request is fraudulent and that such controller shall not comply with such request.

(5) A controller that has obtained personal data about a consumer from a source other than the consumer shall be deemed in compliance with a consumer's request to delete such data pursuant to subdivision (3) of subsection (a) of this section by (A) retaining a record of the deletion request and the minimum data necessary for the purpose of ensuring the consumer's personal data remains deleted from the controller's records and not using such retained data for any other purpose pursuant to the provisions of Section 1 of this act, or (B) opting the consumer out of the processing of such personal data for any purpose except for those exempted pursuant to the provisions of Section 1 of this act.

(d) A controller shall establish a process for a consumer to appeal the controller's refusal to take action on a request within a reasonable period of time after the consumer's receipt of the decision. The appeal process shall be conspicuously available and similar to the process for submitting requests to initiate action pursuant to this section. Not later than sixty days after receipt of an appeal, a controller shall inform the consumer in writing of any action taken or not taken in response to the appeal, including a written explanation of the reasons for the decisions. If the appeal is denied, the controller shall also provide the consumer with an online mechanism,

297 if available, or other method through which the consumer may contact the Attorney General to
298 submit a complaint.

299 Section 5. A consumer may designate another person to serve as the consumer's
300 authorized agent, and act on such consumer's behalf, to opt out of the processing of such
301 consumer's personal data for one or more of the purposes specified in subdivision (5) (A) and (B)
302 of subsection (a) of section 4 of this act. A controller shall comply with an opt-out request
303 received from an authorized agent if the controller is able to verify, with commercially
304 reasonable effort, the identity of the consumer and the authorized agent's authority to act on such
305 consumer's behalf.

306 Section 6. (a) A controller shall: (1) Limit the collection of personal data to what is
307 adequate, relevant and reasonably necessary in relation to the purposes for which such data is
308 processed, as disclosed to the consumer; (2) except as otherwise provided in Section 1 of this act,
309 not process personal data for purposes that are neither reasonably necessary to, nor compatible
310 with, the disclosed purposes for which such personal data is processed, as disclosed to the
311 consumer, unless the controller obtains the consumer's consent; (3) establish, implement and
312 maintain reasonable administrative, technical and physical data security practices to protect the
313 confidentiality, integrity and accessibility of personal data appropriate to the volume and nature
314 of the personal data at issue; (4) not process sensitive data concerning a consumer without
315 obtaining the consumer's consent; (5) in the case of the processing of sensitive data concerning a
316 known child, without processing such data in accordance with COPPA; (6) not process personal
317 data in violation of the laws of this state and federal laws that prohibit unlawful discrimination
318 against consumers; (7) provide an effective mechanism for a consumer to revoke the consumer's
319 consent under this section that is at least as easy as the mechanism by which the consumer

provided the consumer's consent and, upon revocation of such consent, cease to process the data as soon as practicable, but not later than forty-five days after the receipt of such request; and (8) not process the personal data of a consumer for purposes of targeted advertising, or sell the consumer's personal data without the consumer's consent, under circumstances where a controller has actual knowledge, and willfully disregards, that the consumer is at least thirteen years of age but younger than sixteen years of age. A controller shall not discriminate against a consumer for exercising any of the consumer rights contained in Section 4 of this act, including denying goods or services, charging different prices or rates for goods or services or providing a different level of quality of goods or services to the consumer.

(b) Nothing in subsection (a) of this section shall be construed to require a controller to provide a product or service that requires the personal data of a consumer which the controller does not collect or maintain, or prohibit a controller from offering a different price, rate, level, quality or selection of goods or services to a consumer, including offering goods or services for no fee, if the offering is in connection with a consumer's voluntary participation in a bona fide loyalty, rewards, premium features, discounts or club card program.

(c) A controller shall provide consumers with a reasonably accessible, clear and meaningful privacy notice that includes: (1) The categories of personal data processed by the controller; (2) the purpose for processing personal data; (3) how consumers may exercise their consumer rights, including how a consumer may appeal a controller's decision with regard to the consumer's request; (4) the categories of personal data that the controller shares with third parties, if any; (5) the categories of third parties, if any, with which the controller shares personal data; and (6) an active electronic mail address or other mechanism that the consumer may use to contact the controller.

(d) If a controller sells personal data to third parties or processes personal data for targeted advertising, the controller shall clearly and conspicuously disclose such processing, as well as the manner in which a consumer may exercise the right to opt out of such processing.

(e) (1) A controller shall establish, and shall describe in a privacy notice, one or more secure and reliable means for consumers to submit a request to exercise their consumer rights pursuant to this act. Such means shall take into account the ways in which consumers normally interact with the controller, the need for secure and reliable communication of such requests and the ability of the controller to verify the identity of the consumer making the request.

A controller shall not require a consumer to create a new account in order to exercise consumer rights, but may require a consumer to use an existing account. Any such means shall include:

(A) (i) Providing a clear and conspicuous link on the controller's Internet web site to an Internet web page that enables a consumer, or an agent of the consumer, to opt out of the targeted advertising or sale of the consumer's personal data; and

(ii) Not later than July 1, 2025, allowing a consumer to opt out of any processing of the consumer's personal data for the purposes of targeted advertising, or any sale of such personal data, through an opt out preference signal sent, with such consumer's consent, by a platform, technology or mechanism to the controller indicating such consumer's intent to opt out of any such processing or sale. Such platform, technology or mechanism shall:

(I) Not unfairly disadvantage another controller;

(II) Not make use of a default setting, but, rather, require the consumer to make an affirmative, freely given and unambiguous choice to opt out of any processing of such consumer's personal data pursuant to Section 1 of this act;

(III) Be consumer-friendly and easy to use by the average consumer;

(IV) Be as consistent as possible with any other similar platform, technology or mechanism required by any federal or state law or regulation; and

(V) Enable the controller to accurately determine whether the consumer is a resident of this state and whether the consumer has made a legitimate request to opt out of any sale of such consumer's personal data or targeted advertising.

(B) A controller that recognizes opt out preference signals that have been approved by other state laws or regulations shall be deemed to be in compliance with subsection (A) of this section.

(C) If a consumer's decision to opt out of any processing of the consumer's personal data for the purposes of targeted advertising, or any sale of such personal data, through an opt-out preference signal sent in accordance with the provisions of subparagraph (A) of this subdivision conflicts with the consumer's existing voluntary participation in a controller's bona fide loyalty, rewards, premium features, discounts or club card program, the controller shall comply with such consumer's opt-out preference signal but may notify such consumer of such conflict and provide to such consumer the choice to confirm participation in such program.

(2) If a controller responds to consumer opt-out requests received pursuant to subparagraph (A) of subdivision (1) of this subsection by informing the consumer of a charge for

the use of any product or service, the controller shall present the terms of any financial incentive offered pursuant to subsection (b) of this section for the retention, use, sale or sharing of the consumer's personal data.

(f) A controller shall not: (1) use a geofence to establish a virtual boundary that is within one thousand seven hundred fifty feet of any mental health facility or reproductive or sexual health facility for the purpose of identifying, tracking, collecting data from or sending any notification to a consumer regarding the consumer's consumer health data; or (2) sell, or offer to sell, consumer health data without first obtaining the consumer's consent.

Section 7. (a) Each controller that offers any online service, product or feature to consumers whom such controller has actual knowledge, or willfully disregards, are minors shall use reasonable care to avoid any heightened risk of harm to minors caused by such online service, product or feature. In any enforcement action brought by the Attorney General pursuant to this act, there shall be a rebuttable presumption that a controller used reasonable care as required under this section if the controller complied with the provisions of this act concerning data protection assessments.

(b) (1) Subject to the consent requirement established in subdivision (3) of this subsection, no controller that offers any online service, product or feature to consumers whom such controller has actual knowledge, or willfully disregards, are minors shall: (A) Process any minor's personal data (i) for the purposes of (I) targeted advertising, (II) any sale of personal data, or (III) profiling in furtherance of any fully automated decision made by such controller that produces any legal or similarly significant effect concerning the provision or denial by such controller of any financial or lending services, housing, insurance, education enrollment or

406 opportunity, criminal justice, employment opportunity, health care services or access to essential
407 goods or services, (ii) unless such processing is reasonably necessary to provide such online
408 service, product or feature, (iii) for any processing purpose (I) other than the processing purpose
409 that the controller disclosed at the time such controller collected such personal data, or (II) that is
410 reasonably necessary for, and compatible with, the processing purpose described in subparagraph
411 (A)(iii)(I) of this subdivision, or (iv) for longer than is reasonably necessary to provide such
412 online service, product or feature; or (B) use any system design feature to significantly increase,
413 sustain or extend any minor's use of such online service, product or feature. The provisions of
414 this subdivision shall not apply to any service or application that is used by and under the
415 direction of an educational entity, including, but not limited to, a learning management system or
416 a student engagement program.

417 (2) Subject to the consent requirement established in subdivision (3) of this subsection,
418 no controller that offers an online service, product or feature to consumers whom such controller
419 has actual knowledge, or willfully disregards, are minors shall collect a minor's precise
420 geolocation data unless: (A) Such precise geolocation data is reasonably necessary for the
421 controller to provide such online service, product or feature and, if such data is necessary to
422 provide such online service, product or feature, such controller may only collect such data for the
423 time necessary to provide such online service, product or feature; and (B) the controller provides
424 to the minor a signal indicating that such controller is collecting such precise geolocation data,
425 which signal shall be available to such minor for the entire duration of such collection.

426 (3) No controller shall engage in the activities described in subdivisions (1) and (2) of
427 this subsection unless the controller obtains the minor's consent or, if the minor is younger than
428 thirteen years of age, the consent of such minor's parent or legal guardian. A controller that

complies with the verifiable parental consent requirements established in the Children's Online Privacy Protection Act of 1998, 15 USC 6501 et seq., and the regulations, rules, guidance and exemptions adopted pursuant to said act, as said act and such regulations, rules, guidance and exemptions may be amended from time to time, shall be deemed to have satisfied any requirement to obtain parental consent under this subdivision.

(c) (1) No controller that offers any online service, product or feature to consumers whom such controller has actual knowledge, or willfully disregards, are minors shall: (A) Provide any consent mechanism that is designed to substantially subvert or impair, or is manipulated with the effect of substantially subverting or impairing, user autonomy, decision-making or choice; or (B) except as provided in subdivision (2) of this subsection, offer any direct messaging apparatus for use by minors without providing readily accessible and easy-to-use safeguards to limit the ability of adults to send unsolicited communications to minors with whom they are not connected.

(2) The provisions of subparagraph (B) of subdivision (1) of this subsection shall not apply to services where the predominant or exclusive function is: (A) Electronic mail; or (B) direct messaging consisting of text, photos or videos that are sent between devices by electronic means, where messages are (i) shared between the sender and the recipient, (ii) only visible to the sender and the recipient, and (iii) not posted publicly.

Section 8. (a) A processor shall adhere to the instructions of a controller and shall assist the controller in meeting the controller's obligations under Section 1 of this act. Such assistance shall include: (1) Taking into account the nature of processing and the information available to the processor, by appropriate technical and organizational measures, insofar as is reasonably practicable, to fulfill the controller's obligation to respond to consumer rights requests; (2) taking

into account the nature of processing and the information available to the processor, by assisting the controller in meeting the controller's obligations in relation to the security of processing the personal data and in relation to the notification of a breach of security pursuant to chapter 93H of the General Laws, of the system of the processor, in order to meet the controller's obligations; and (3) providing necessary information to enable the controller to conduct and document data protection assessments.

(b) A contract between a controller and a processor shall govern the processor's data processing procedures with respect to processing performed on behalf of the controller. The contract shall be binding and clearly set forth instructions for processing data, the nature and purpose of processing, the type of data subject to processing, the duration of processing and the rights and obligations of both parties. The contract shall also require that the processor: (1) Ensure that each person processing personal data is subject to a duty of confidentiality with respect to the data; (2) at the controller's direction, delete or return all personal data to the controller as requested at the end of the provision of services, unless retention of the personal data is required by law; (3) upon the reasonable request of the controller, make available to the controller all information in its possession necessary to demonstrate the processor's compliance with the obligations in Section 1 of this act; and (4) allow, and cooperate with, reasonable assessments by the controller or the controller's designated assessor, or the processor may arrange for a qualified and independent assessor to conduct an assessment of the processor's policies and technical and organizational measures in support of the obligations under Section 1 of this act, using an appropriate and accepted control standard or framework and assessment procedure for such assessments. The processor shall provide a report of such assessment to the controller upon request; and (5) engage any subcontractor pursuant to a written contract that

requires the subcontractor to meet the obligations of the processor with respect to the personal data.

(c) Nothing in this section shall be construed to relieve a controller or processor from the liabilities imposed on the controller or processor by virtue of such controller's or processor's role in the processing relationship, as described in Section 1 of this act.

(d) Determining whether a person is acting as a controller or processor with respect to a specific processing of data is a fact-based determination that depends upon the context in which personal data is to be processed. A person who is not limited in such person's processing of personal data pursuant to a controller's instructions, or who fails to adhere to such instructions, is a controller and not a processor with respect to a specific processing of data. A processor that continues to adhere to a controller's instructions with respect to a specific processing of personal data remains a processor. If a processor begins, alone or jointly with others, determining the purposes and means of the processing of personal data, the processor is a controller with respect to such processing and may be subject to an enforcement action under section 12 of this act.

Section 9. (a) A controller shall conduct and document a data protection assessment for each of the controller's processing activities that presents a heightened risk of harm to a consumer. For the purposes of this section, processing that presents a heightened risk of harm to a consumer includes: (1) The processing of personal data for the purposes of targeted advertising; (2) the sale of personal data; (3) the processing of personal data for the purposes of profiling, where such profiling presents a reasonably foreseeable risk of (A) unfair or deceptive treatment of, or unlawful disparate impact on, consumers, (B) financial, physical or reputational injury to consumers, (C) a physical or other intrusion upon the solitude or seclusion, or the

private affairs or concerns, of consumers, where such intrusion would be offensive to a reasonable person, or (D) other substantial injury to consumers; and (4) the processing of sensitive data.

(b) Data protection assessments conducted pursuant to subsection (a) of this section shall identify and weigh the benefits that may flow, directly and indirectly, from the processing to the controller, the consumer, other stakeholders and the public against the potential risks to the rights of the consumer associated with such processing, as mitigated by safeguards that can be employed by the controller to reduce such risks. The controller shall factor into any such data protection assessment the use of de-identified data and the reasonable expectations of consumers, as well as the context of the processing and the relationship between the controller and the consumer whose personal data will be processed.

(c) Each controller that, as of the effective date of this act, offers any online service, product or feature to consumers whom such controller has actual knowledge, or willfully disregards, are minors shall conduct a data protection assessment for such online service, product or feature (1) in a manner that is consistent with this section; and (2) that addresses (A) the purpose of such online service, product or feature; (B) the categories of minors' personal data that such online service, product or feature processes, (C) the purposes for which such controller processes minors' personal data with respect to such online service, product or feature, and (D) any heightened risk of harm to minors that is a reasonably foreseeable result of offering such online service, product or feature to minors.

(d) Each controller that conducts a data protection assessment pursuant to subsection (c) of this section shall: (1) Review such data protection assessment as necessary to account for any

material change to the processing operations of the online service, product or feature that is the subject of such data protection assessment; and (2) maintain documentation concerning such data protection assessment for the longer of (A) the three-year period beginning on the date on which such processing operations cease, or (B) as long as such controller offers such online service, product or feature.

(c) The Attorney General may require that a controller disclose any data protection assessment that is relevant to an investigation conducted by the Attorney General, and the controller shall make the data protection assessment available to the Attorney General. The Attorney General may evaluate the data protection assessment for compliance with the responsibilities set forth in this act. Data protection assessments shall be confidential and shall be exempt from disclosure under the Public Records Act, as set forth in chapter 66 of the General Laws. To the extent any information contained in a data protection assessment disclosed to the Attorney General includes information subject to attorney-client privilege or work product protection, such disclosure shall not constitute a waiver of such privilege or protection.

(d) A single data protection assessment may address a comparable set of processing operations that include similar activities.

(e) If a controller conducts a data protection assessment for the purpose of complying with another applicable law or regulation, the data protection assessment shall be deemed to satisfy the requirements established in this section if such data protection assessment is reasonably similar in scope and effect to the data protection assessment that would otherwise be conducted pursuant to this section.

(f) Data protection assessment requirements shall apply to processing activities created or generated after January 1, 2024, and are not retroactive.

Section 10. (a) Any controller in possession of de-identified data shall: (1) Take reasonable measures to ensure that the data cannot be associated with an individual; (2) publicly commit to maintaining and using de-identified data without attempting to reidentify the data; and (3) contractually obligate any recipients of the deidentified data to comply with all provisions of Section 1 of this act.

(b) Nothing in this act shall be construed to: (1) Require a controller or processor to re-identify de-identified data or pseudonymous data; or (2) maintain data in identifiable form, or collect, obtain, retain or access any data or technology, in order to be capable of associating an authenticated consumer request with personal data.

(c) Nothing in this act shall be construed to require a controller or processor to comply with an authenticated consumer rights request if the controller: (1) Is not reasonably capable of associating the request with the personal data or it would be unreasonably burdensome for the controller to associate the request with the personal data; (2) does not use the personal data to recognize or respond to the specific consumer who is the subject of the personal data, or associate the personal data with other personal data about the same specific consumer; and (3) does not sell the personal data to any third party or otherwise voluntarily disclose the personal data to any third party other than a processor, except as otherwise permitted in this section.

(d) The rights afforded under subdivisions (1) to (4), inclusive, of subsection (a) of section 4 of this act shall not apply to pseudonymous data in cases where the controller is able to

demonstrate that any information necessary to identify the consumer is kept separately and is subject to effective technical and organizational controls that prevent the controller from accessing such information.

(e) A controller that discloses pseudonymous data or de-identified data shall exercise reasonable oversight to monitor compliance with any contractual commitments to which the pseudonymous data or de-identified data is subject and shall take appropriate steps to address any breaches of those contractual commitments.

Section 11. (a) Nothing in this act shall be construed to restrict a controller's or processor's ability to: (1) Comply with federal, state or municipal ordinances or regulations; (2) comply with a civil, criminal or regulatory inquiry, investigation, subpoena or summons by federal, state, municipal or other governmental authorities; (3) cooperate with law enforcement agencies concerning conduct or activity that the controller or processor reasonably and in good faith believes may violate federal, state or municipal ordinances or regulations; (4) investigate, establish, exercise, prepare for or defend legal claims; (5) provide a product or service specifically requested by a consumer; (6) perform under a contract to which a consumer is a party, including fulfilling the terms of a written warranty; (7) take steps at the request of a consumer prior to entering into a contract; (8) take immediate steps to protect an interest that is essential for the life or physical safety of the consumer or another individual, and where the processing cannot be manifestly based on another legal basis; (9) prevent, detect, protect against or respond to security incidents, identity theft, fraud, harassment, malicious or deceptive activities or any illegal activity, preserve the integrity or security of systems or investigate, report or prosecute those responsible for any such action; (10) engage in public or peer-reviewed scientific or statistical research in the public interest that adheres to all other applicable ethics

and privacy laws and is approved, monitored and governed by an institutional review board that determines, or similar independent oversight entities that determine, (A) whether the deletion of the information is likely to provide substantial benefits that do not exclusively accrue to the controller, (B) the expected benefits of the research outweigh the privacy risks, and (C) whether the controller has implemented reasonable safeguards to mitigate privacy risks associated with research, including any risks associated with re-identification; (11) assist another controller, processor or third party with any of the obligations under Section 1 of this act; or (12) process personal data for reasons of public interest in the area of public health, community health or population health, but solely to the extent that such processing is (A) subject to suitable and specific measures to safeguard the rights of the consumer whose personal data is being processed, and (B) under the responsibility of a professional subject to confidentiality obligations under federal, state or local law.

(b) The obligations imposed on controllers or processors under Section 1 of this act shall not restrict a controller's or processor's ability to collect, use or retain data for internal use to: (1) Conduct internal research to develop, improve or repair products, services or technology; (2) effectuate a product recall; (3) identify and repair technical errors that impair existing or intended functionality; or (4) perform internal operations that are reasonably aligned with the expectations of the consumer or reasonably anticipated based on the consumer's existing relationship with the controller, or are otherwise compatible with processing data in furtherance of the provision of a product or service specifically requested by a consumer or the performance of a contract to which the consumer is a party.

(c) The obligations imposed on controllers or processors under Section 1 of this act shall not apply where compliance by the controller or processor with said sections would violate

an evidentiary privilege under the laws of this state. Nothing in this act shall be construed to prevent a controller or processor from providing personal data concerning a consumer to a person covered by an evidentiary privilege under the laws of the state as part of a privileged communication.

(d) A controller or processor that discloses personal data to a processor or third-party controller in accordance with of this act shall not be deemed to have violated said sections if the processor or third-party controller that receives and processes such personal data violates said sections, provided, at the time the disclosing controller or processor disclosed such personal data, the disclosing controller or processor did not have actual knowledge that the receiving processor or third-party controller would violate said sections. A third-party controller or processor receiving personal data from a controller or processor in compliance with of this act is likewise not in violation of said sections for the transgressions of the controller or processor from which such third-party controller or processor receives such personal data.

(e) Nothing in this act shall be construed to: (1) Impose any obligation on a controller or processor that adversely affects the rights or freedoms of any person, including, but not limited to, the rights of any person to freedom of speech or freedom of the press guaranteed in the First Amendment to the United States Constitution; or (2) apply to any person's processing of personal data in the course of such person's purely personal or household activities.

(f) Personal data processed by a controller pursuant to this section may be processed to the extent that such processing is: (1) Reasonably necessary and proportionate to the purposes listed in this section; and (2) adequate, relevant and limited to what is necessary in relation to the specific purposes listed in this section. Personal data collected, used or retained pursuant to

subsection (b) of this section shall, where applicable, take into account the nature and purpose or purposes of such collection, use or retention. Such data shall be subject to reasonable administrative, technical and physical measures to protect the confidentiality, integrity and accessibility of the personal data and to reduce reasonably foreseeable risks of harm to consumers relating to such collection, use or retention of personal data.

(g) If a controller processes personal data pursuant to an exemption in this section, the controller bears the burden of demonstrating that such processing qualifies for the exemption and complies with the requirements in subsection (f) of this section.

(h) Processing personal data for the purposes expressly identified in this section shall not solely make a legal entity a controller with respect to such processing.

Section 12. (a) The Attorney General shall have exclusive authority to enforce violations this act.

(b) During the period beginning on July 1, 2026 and ending on December 31, 2027, the Attorney General shall, prior to initiating any action for a violation of any provision of this act, issue a notice of violation to the controller if the Attorney General determines that a cure is possible. If the controller fails to cure such violation within sixty days of receipt of the notice of violation, the Attorney General may bring an action pursuant to this section.

(c) Not later than February 1, 2027, the Attorney General shall submit a report, in accordance with to the joint standing committee of the General Assembly having cognizance of matters relating to the judiciary disclosing: (1) The number of notices of violation the Attorney General has issued; (2) the nature of each violation; (3) the number of violations that were cured

650 during the sixty-day cure period; and (4) any other matter the Attorney General deems relevant
651 for the purposes of such report.

652 (d) Beginning on January 1, 2028, the Attorney General may, in determining whether to
653 grant a controller or processor the opportunity to cure an alleged violation described in
654 subsection (b) of this section, consider: (1) The number of violations; (2) the size and complexity
655 of the controller or processor; (3) the nature and extent of the controller's or processor's
656 processing activities; (4) the substantial likelihood of injury to the public; (5) the safety of
657 persons or property; and (6) whether such alleged violation was likely caused by human or
658 technical error.

659 (d) Nothing in section 1 of this act shall be construed as providing the basis for, or be
660 subject to, a private right of action for violations of said section or any other law.

661 (e) A violation of the requirements of this act shall constitute an unfair trade practice
662 for purposes of Chapter 93A of the General Laws. Notwithstanding section 9 of said chapter
663 93A, the provisions of this act shall be enforced solely by the Attorney General.

664 Section 13. This act shall be effective July 1, 2026